智银通 V3.1 金融安全自评报告

本地模拟系统安全控制与验收证据

结论：在当前冻结源码与约定测试范围内，90 项完整验收全部通过。此报告属于项目自评，不是第三方认证、银行生产准入证明或无漏洞保证。所有资金执行仅发生于独立模拟账本。

版本基准：V3.1 安全修订版 | 资料核验日期：2026 年 11 月 1 日

批次	总数	通过	失败/错误/跳过
历史基础安全	43	43	0 / 0 / 0
历史含智能分析	55	55	0 / 0 / 0
原最终安全审计	70	70	0 / 0 / 0
最新完整独立集合	90	90	0 / 0 / 0

集合关系为 43 ⊂ 55 ⊂ 70 ⊂ 90。原 70 项与新增策略测试 20 项互斥，组成完整 90 项。其他批次不可重复累加。

测试文件	用例数
test_banking_v3.py	41
test_security_acceptance.py	2
test_intelligence.py	12
test_final_security_audit.py	15
test_policy_binding_v31.py	20

实现与证据 最终验收日期 2026-11-01；证据来自 backend/test-results/v31-security。

01 系统安全概述

自评结论：当前冻结版本在本地模拟系统的 90 项完整验收中全部通过，未跳过安全测试。该结论基于已保存的 JUnit XML、真实 HTTP 证据和源码对照，适用范围仅为开发身份、模拟 MFA 和独立模拟账本。

本轮交付制作没有修改核心业务代码，也不将过去的测试记录冒充本轮新跑结果。真实银行生产身份、真实支付通道及生产认证均为 NOT VERIFIED。

实现与证据 FINAL_SECURITY_ACCEPTANCE_V3_1.md；full/v31-acceptance.xml

02 安全架构与威胁模型

保护对象为模拟资金、预留、授权记录、会话与审计。主要威胁包括提示注入、客户端伪造身份、普通用户越权、重复提交、旧授权重放、计划篡改、审计故障和策略切换竞态。攻击面覆盖浏览器、REST、SSE、Agent/MCP 工具及数据库访问。

控制点沿输入、身份、委托链、工具权限和执行数据五个平面分布。攻击者可构造客户端请求，但不假定其具有服务器管理员权限；若管理员可改代码或移除数据库触发器，本机哈希链不能单独提供可信外部证明。

实现与证据 backend/agent_runtime.py:180、258；backend/services/policy_service.py

03 身份认证与权限管理

IdentityAuditMiddleware 从 Bearer 会话读取服务端主体、角色与有效期，客户端 actor_id/reviewer 不能成为授权依据。开发登录仅映射固定账号到 customer 或 supervisor，密码须独立配置且至少 16 字符；数据库只存会话令牌哈希。

非 development 环境不提供开发认证，生产身份适配器未配置时拒绝访问。独立账号与角色测试证明应用层访问隔离，不证明自然人、设备或组织管理上的独立性。

实现与证据 backend/services/auth_service.py:24、47；backend/services/api_v3.py:61

04 GREEN YELLOW RED 权限分级

权限从服务端动作目录计算。GREEN 是查询计算；YELLOW 是显式确认；RED 包含高风险模拟写操作。模型输出与 UI 卡片均不能自行提升权限。TrustEngine 局部 ALLOW 不能直接触发账本变化。

审计控制台明确提示 RED ALLOW 不等于最终执行授权。统计或日志必须关联同一工作流的 Maker、MFA、审批和最终事务事件，不能仅凭一个 ALLOW 断定违规放行或交易成功。

实现与证据 backend/agent_runtime.py:180；frontend/components/AuditConsole.jsx

05 高风险操作确认

网关按金额分值比较阈值：严格大于 50,000 元需要人工接管与主管复核。满足资金条件的 50,001 元交易先完成 Maker 和 MFA，再进入等待人工状态；等待中直接请求执行必须拒绝。

默认演示余额 10,000 元且保护性预留 6,000 元，不能完成 50,001 元沙箱。测试中的大额场景使用临时高余额合成账户，不修改原有业务数据，也不把预置测试余额描述为真实资金。

实现与证据 backend/services/execution_gateway.py:52、126；backend/tests/test_policy_binding_v31.py

06 MFA 验证机制

MFA 绑定 Maker 主体与 authorization_digest，并具有 300 秒有效期。缺少验证、确认顺序错误、过期或摘要改变都会阻断后续审批与执行。最终执行不能仅检查 mfa_verified 布尔值。

当前使用显式模拟验证分支，仅用于 development。真实短信、硬件密钥和生物识别未接入，因此自评中“通过”只表示状态机与绑定检查通过，不代表认证因素安全已获生产证明。

实现与证据 backend/services/execution_gateway.py:116、126

07 Maker Checker 双人复核

审批者须为服务端 supervisor，且与 Maker 主体不同。Maker 自审批和另一个普通用户审批均返回拒绝。审批记录包含完整授权摘要、策略版本、策略指纹、计划哈希、角色与时间。

Checker 拒绝后工作流为 REJECTED 终态，不能再次审批恢复；变更金额、收款对象或动作会使快照不一致。旧接口只提交 plan_hash 不意味着仅校验该字段，后端还校验不可变快照及全部授权记录。

实现与证据 backend/services/execution_gateway.py:126；backend/services/api_v3.py:142

08 HITL 人工接管

大额工作流经 MFA 后为 PENDING_HUMAN_REVIEW，提交复核后为 AWAITING_CHECKER，主管通过后才可能 APPROVED。等待与拒绝状态均由后端维护，不依赖隐藏按钮。

人工接管在当前版本是开发身份审批状态机，没有真实机构的工单系统、组织职责矩阵或主管在岗核验。未来接入这些能力前，不能以“两个日志身份”声称银行双人复核完全落地。

实现与证据　backend/services/execution_gateway.py:126；frontend/components/CheckerApprovalModal.jsx

09 Sandbox 隔离执行

沙箱针对独立模拟账本检查 DAG、动作、对象、金额和预留。整数分运算与条件更新防止余额不足时提交。原沙箱结果进入快照，最终执行再检查当前余额，不允许用过时可用余额绕过约束。

本轮截图使用全新临时账本，既有业务库未用于素材交易。模拟分录不涉及银行账户、清算网络或真实财产转移。

实现与证据　backend/services/sandbox_service.py:15、32、67

10 Idempotency 防重放

幂等键按认证主体和操作作用域持久化，绑定请求哈希。相同键不同请求冲突，相同已完成请求返回一次执行结果；分录的工作流唯一约束提供额外保护。

SQLite BEGIN IMMEDIATE 串行化竞争写入，授权检查、余额更新、分录、审计和幂等完成在事务内提交。缓存返回前仍验证策略快照，策略变化不能借缓存恢复旧许可。

实现与证据　backend/services/idempotency_service.py:15；backend/services/execution_gateway.py:126

11 Audit Trail 审计追踪

事件使用服务端主体与 UTC 时间，记录权限、状态、拒绝原因和耗时。递归脱敏覆盖敏感键；追加触发器和前序哈希构成完整性链。审计写入失败时资金事务回滚，失败请求另行尝试记录拒绝原因。

历史数据保护结论应准确表述为“业务表与原历史审计前缀未变”。在线服务曾新增过期会话认证拒绝审计，因此不能宣称所有数据库表在运行期间完全静止。原始全表比较失败及后续调查均被保留，没有删除日志掩盖差异。

实现与证据　backend/services/audit_service.py:12、49、61；FINAL_SECURITY_ACCEPTANCE_V3_1.md 在线审计追加

12 策略版本绑定

服务端将策略版本、代码与配置指纹、代次、完整计划、Maker、幂等键及沙箱结果共同哈希。快照表不可修改，Maker/MFA/Checker 记录均绑定相同 authorization_digest。

最终网关在同一写事务内重新读取当前策略，比较原快照和审批记录。客户端不能覆盖策略版本，也不能通过替换 plan_hash 获得另一笔交易的批准。

实现与证据 backend/services/policy_service.py:21、107、112、120

13 旧授权失效机制

策略版本或指纹发生变化后，未完成工作流被标记 POLICY_STALE；旧 Maker、MFA、Checker 和沙箱许可清除。失效是不可恢复终态，必须重新创建工作流与幂等键并重新授权。策略代次阻止版本字符串回滚后恢复旧审批。

最重要的负向测试按创建、沙箱、Maker、MFA、Checker、更新策略、执行的顺序复现旧缺陷。最新记录显示 HTTP 拒绝、零余额变化、零新增分录、零 execution_started/completed，且审计链有效。旧版本 HTTP 200 COMPLETED 的失败历史没有被当作通过。

实现与证据 backend/tests/test_policy_binding_v31.py；POLICY_VERSION_BINDING_AUDIT.md

14 数据保护与隐私控制

源码交付排除实际 .env、业务数据库、会话、Cookie、真实凭据、虚拟环境与缓存。提供空密钥模板；开发口令由部署者本地产生。素材和示例使用固定模拟数字及临时会话，不公开用户数据库。

代码中的合成测试口令是非生产测试夹具，不是部署凭据。后续真实数据接入还需最小化采集、访问审批、加密与保留期限管理；这些生产隐私治理措施尚未在本原型中全部实现。

实现与证据 backend/services/audit_service.py:12；源码包 SECURITY.md 与 .env.example

15 API 安全

StrictModel 拒绝未知字段，金额、UUID、审批哈希及动作枚举受 Schema 校验。认证中间件对 API 与 MCP 入口验证会话；工作流和 SSE 按主体或主管角色隔离。直接调用执行接口与点击前端按钮遵循同一网关。

服务端默认拒绝未配置的生产身份，审计不可用返回 503。当前未提供完整生产级 WAF、分布式限流、TLS 终端或机构 OAuth 集成，部署于公网前必须补齐。

实现与证据 backend/services/api_v3.py:25、61、193；backend/services/auth_service.py:47

16 异常处理和失败关闭机制

交易前完成策略、身份、Maker、MFA、Checker、沙箱、幂等及资金约束检查。检查失败返回 403/409 并回滚，不产生 execution_started 或账本提交。成功执行审计已纳入同一事务，避免资金成功后审计失败的窗口。

SQLite 使用 WAL 与同步提交；连接上下文结束显式关闭。数据库或审计故障不降级为前端“成功”。这验证了本地事务边界，不等同于银行级跨机房灾备、分布式两阶段提交或故障恢复认证。

实现与证据 backend/services/execution_gateway.py:126；backend/services/database.py

17 负向安全测试

覆盖无 Checker 执行、Maker 自审、普通用户冒充主管、Checker 拒绝后执行、金额篡改、直接调用执行接口、旧审批重放、并发重复执行和 MFA 缺失。策略专项进一步覆盖不同阶段变更、同版本指纹变化、策略切换竞争、审计写入失败和沙箱不匹配。

新增 20 项测试采用独立真实 HTTP 子进程与临时数据库，记录响应及数据库结果。断言同时检查状态、余额、分录与事件，而不只检查 HTTP 错误码。所有测试结果以保存的最终 XML 为准，未删除或降低原失败用例断言。

实现与证据 backend/tests/test_policy_binding_v31.py；NEGATIVE_SECURITY_TEST_REPORT.md

18 安全测试统计

唯一完整测试集为 90 项：41 + 2 + 12 + 15 + 20。43 项批次为基础安全 41 与专项 2；55 项增加智能分析 12；70 项再增加最终审计 15；90 项增加策略修复 20。历史批次与完整批次重叠，不得相加为 258 或其他“总测试量”。

各最终批次均 0 失败、0 错误、0 跳过。前端构建、依赖检查、服务重启健康及持久化证据在验收目录中保存。中间构建或测试失败不代表最终版本，但必须与最终冻结结果区分，不能删除后只宣传成功。

实现与证据 backend/test-results/v31-security/results.json；full/v31-acceptance.xml

19 当前安全局限性

未连接真实银行，未验证生产 IdP、真实 MFA、自然人岗位隔离、外部审计锚点、银行级负载、渗透测试和监管认证。规则式风险判断与数字孪生未经过真实金融数据校准。当前数据库及任务总线适合单机演示。

本报告不是外部审计机构意见，也不是无漏洞保证。高风险实验的账户余额和交易对象均为合成数据；开发环境允许的模拟路径必须在生产中保持关闭。

实现与证据 FINAL_SECURITY_ACCEPTANCE_V3_1.md 安全边界

20 后续安全建设规划

第一阶段接入机构 IdP、强 MFA 和职责分离；第二阶段增加外部审计锚点、集中事件总线和可靠灾备；第三阶段审查真实连接器、执行监管与隐私评估，并由独立团队开展渗透与容量测试。

每一阶段建立新的验收基线，重新验证授权摘要、策略切换、幂等和失败关闭。当前材料只交付已经实现的模拟能力，不将路线图当作现有银行生产功能。

实现与证据 本报告局限性及当前架构映射

附录 A 关键负向测试真实证据

测试名称：test_policy_change_at_each_stage[checker]。创建 50,001 元模拟转账，完成 Maker、模拟 MFA 和主管审批，再更新当前策略并执行旧工作流。专用临时账户初始余额为 2,000,000 元；本例不是默认 10,000 元账户。

检查项	记录结果
workflow_id	8179e25446784c07828e04172f077b33
POST /execute	HTTP 409
工作流状态	POLICY_STALE
余额变化 / 新增分录	0 元 / 0 条
execution_started / completed	0 / 0
旧主管审批 / Maker 重试	HTTP 409 / HTTP 409
审计链	测试断言通过

实现与证据 evidence/policy-http/test_policy_change_at_each_stage_checker.json；test_policy_binding_v31.py；JUnit 中对应测试无 failure/error/skipped。

审计证据包含 policy_stale 和 execution_blocked，旧快照仍保留。完整 HTTP 请求与响应在源码包 evidence/policy-http 下，均来自临时合成环境。没有把一条拒绝日志替代余额及分录检查。

附录 B 验收边界与数据保护

历史验收核对发现业务表与原审计前缀保持一致，但在线服务追加了过期会话认证拒绝事件。原全表相等检查曾失败并被保留，后续逐条调查解释了差异。故本报告不声称数据库运行期间完全静止。截图采集使用新临时数据库，不读写原账本。